

Security+ 1.2 · AAA (Authentication, Authorization, Accounting)

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.2 — AAA (Authentication, Authorization, Accounting) (9:03)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: AAA: Authentication (proves who you are), Authorization (what you can do), Accounting (records what you did). 802.1X uses RADIUS for network AAA — anyone connecting the cable must authenticate before gaining access.

High-Yield Core Concepts Tested on Exam

- 'Prove who you are, define what you can do, record what you did'
- 802.1X: physical network access requires login — without it, any device can enter
- RADIUS = the central AAA backend

Exam Tips & Classic Scenarios

- The exam mentions: 'network access control requires users to authenticate' = 802.1X + RADIUS
- Accounting = access LOG (who entered when) — not financial accounting

Typical Exam Scenario: Typical scenario: 'company needs to control which device and user accesses the switch' → 802.1X with RADIUS.

Beyond the Video: Official CompTIA Exam Concepts, Protocols &

Traps (Lesson 1.2 — AAA (Authentication, Authorization, Accounting))

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **TACACS+:** Terminal Access Controller Access-Control System Plus: Enterprise AAA protocol running over TCP port 49; fully encrypts the entire packet payload and decouples authentication from authorization, enabling granular per-command control on network switches and routers.
- **RADIUS:** Remote Authentication Dial-In User Service: Client/server AAA protocol (UDP ports 1812/1813) standard in 802.1X and VPN environments; encrypts only the password field and combines authentication and authorization.
- **WPA3-ENTERPRISE:** Enterprise Wi-Fi security standard employing 802.1X with a centralized RADIUS backend and 192-bit cryptographic strength (NSA Suite B / CNSA compliant).
- **NAS:** Network Access Server: Gateway/authenticator device (such as a Wi-Fi Access Point or managed switch) that acts as a pass-through intermediary between supplicant clients and authentication servers.
- **802.1X:** IEEE standard for Port-Based Network Access Control (PNAC). Restricts unauthorized network access at the physical port or wireless layer until credentials are authenticated via RADIUS.
- **SAML:** Security Assertion Markup Language (SAML 2.0): XML-based standard for exchanging authentication and authorization assertions between an Identity Provider (IdP) and Service Providers (SPs) in enterprise web Single Sign-On (SSO).
- **IDP:** Identity Provider: Centralized system (e.g. Microsoft Entra ID, Okta, ADFS) responsible for authenticating users and issuing trusted digital identity tokens/assertions.
- **SP:** Service Provider: Web application or cloud SaaS service (e.g. Salesforce, M365) that relies on the Identity Provider to authenticate users and grant access.
- **ADFS:** Active Directory Federation Services: Microsoft Identity Provider (IdP) solution utilizing SAML and WS-Federation to extend on-premises Active Directory SSO to cloud SaaS applications.
- **WAF:** Web Application Firewall: Layer 7 security inspection appliance/service that inspects and filters HTTP/HTTPS payloads against OWASP Top 10 exploits such as SQL Injection, XSS, and CSRF.
- **SAAS:** Software as a Service: Cloud delivery model where the provider hosts and manages the entire application and infrastructure, with customers consuming the service over the web.

- **DNSSEC:** DNS Security Extensions: Cryptographically signs DNS zone records with asymmetric keys to ensure origin authenticity and data integrity, preventing DNS cache poisoning.
- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).
- **SIEM:** Security Information and Event Management: Centralized platform performing real-time ingestion, normalization, correlation, and alerting across multi-source security telemetry.

 Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

 Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An employee taps their RFID chip badge and enters their PIN at an access turnstile. The turnstile then verifies whether the employee is allowed to enter the server room at that time. Finally, it records the date, time, and event ID in the database. Which pillars of the AAA model were exercised, respectively?

- A)** Accounting, Authorization, Authentication
- B)** Authentication, Authorization, Accounting
- C)** Authorization, Accounting, Authentication
- D)** Authentication, Accounting, Auditing

2. A network administrator needs to implement the 802.1X standard to authenticate computers before they receive traffic on the corporate local network. Which protocol is the industry-standard choice to act as the central AAA server in this topology?

- A) RADIUS (Remote Authentication Dial-In User Service)**
- B) SNMPv3**
- C) DNSSEC**
- D) NTP**

3. What is the fundamental difference between AUTHENTICATION and AUTHORIZATION in the AAA model?

- A) Authentication verifies identity ('who you are'); Authorization defines privileges and access ('what you can do')**
- B) Authentication generates accounting reports; Authorization creates network accounts**
- C) Authentication only works in the cloud; Authorization is exclusive to local networks**
- D) There is no technical difference; they are interchangeable terms**

4. During a forensic audit after an internal leak, the security team discovers that changes to a confidential file were not logged and there is no history of who accessed the folder. Which AAA pillar failed in this infrastructure?

- A) Accounting (Auditing / Log accounting)**
- B) Authentication**
- C) Availability**
- D) Authorization**

5. A network engineer must choose between RADIUS and TACACS+ for managing corporate routers and switches. Which characteristic makes TACACS+ superior for command control on network devices?

- A) TACACS+ completely separates authentication and authorization and encrypts the entire TCP packet (port 49)**
- B) TACACS+ does not require passwords or certificates**
- C) RADIUS encrypts the entire packet while TACACS+ encrypts nothing**
- D) RADIUS uses guaranteed TCP while TACACS+ uses UDP without confirmation**

6. A company enforces mandatory multifactor authentication (MFA) for VPN. A user enters username/password and receives a push code on their smartphone. Which AAA pillar was successfully completed when validating these factors?

- A) Authentication**
- B) Accounting**
- C) Federation**
- D) Authorization**

7. An IT intern can authenticate normally to the Active Directory domain, but when trying to open the payroll share on the file server, receives an 'Access Denied' message. What does this demonstrate?

- A) Authentication was successful, but Authorization was denied by the privilege policy**
- B) The AAA model was corrupted and the server crashed**
- C) The Accounting audit blocked the user due to inactivity**
- D) The user needs to change their asymmetric key**

8. In a corporate wireless network architecture (WPA3-Enterprise), what role does the Wi-Fi Access Point (AP) play in AAA communication?

- A) Acts as the Authenticator (Network Access Server - NAS), mediating packets between the client and the RADIUS server**
- B) Acts as the password database server itself**
- C) Acts as an offline root certificate authority**
- D) Plays only the Accounting role without touching authentication**

9. To prevent an attacker who has compromised a server from deleting the Accounting logs that record their malicious activities, which measure is recommended by CompTIA best practices?

- A) Real-time log forwarding to a centralized external SIEM server with WORM retention rules**
- B) Storing logs only in volatile RAM**
- C) Automatically deleting logs every 24 hours**
- D) Disabling logs on accounts with administrator privileges**

10. A corporate web system uses SAML 2.0 to allow employees to access cloud tools (SaaS) using their single network credential. What is the role of Active Directory Federated Services (ADFS) in this AAA flow?

- A)** Identity Provider (IdP), responsible for authenticating the user and issuing the assertion token
- B)** Service Provider (SP), responsible only for hosting email
- C)** Reverse proxy server without a security function
- D)** Web Application Firewall (WAF)

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Authentication, Authorization, Accounting.

✓ **Why it's correct:** Badge + PIN prove who he is (Authentication); checking permission and time is Authorization; recording the entry with a timestamp in the log is Accounting.

✗ **Why the others are wrong:**

- *Accounting, Authorization, Authentication:* Reverses or confuses the strict sequence of the AAA model (first authenticate to prove who you are, then authorize access to resources, and finally log actions in accounting).
- *Authorization, Accounting, Authentication:* Reverses or confuses the strict sequence of the AAA model (first authenticate to prove who you are, then authorize access to resources, and finally log actions in accounting).
- *Authentication, Accounting, Auditing:* Does not meet the technical requirement presented in the scenario, contradicting the best practices and controls required by the CompTIA Security+ exam.

2) A — RADIUS (Remote Authentication Dial-In User Service).

The correct answer is RADIUS (Remote Authentication Dial-In User Service). RADIUS (or TACACS+) is the standard backend AAA (Authentication, Authorization, Accounting) service integrated with 802.1X to authenticate devices and users before granting access to switch ports and Wi-Fi networks. It centralizes credential validation and policy enforcement. Distractor breakdown: • *SNMPv3:* Incorrect. SNMPv3 is a network management protocol used for monitoring and configuring network devices, not for centralized authentication. • *DNSSEC:* Incorrect. DNSSEC provides cryptographic authentication and integrity for DNS data, not user or device authentication for network access. • *NTP:* Incorrect. NTP (Network Time Protocol) synchronizes clocks across systems; it does not perform authentication or authorization.

3) A — Authentication verifies identity ('who you are'); Authorization defines privileges and access ('what you can do').

✓ **Why it is correct:** Authentication validates credentials to confirm identity. Authorization applies permission policies that determine which resources the authenticated user can access.

✗ **Why the others are wrong:**

- *Authentication generates accounting reports; Authorization creates network accounts:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Authentication only works in the cloud; Authorization is exclusive to local networks:* Legacy cipher with insufficient key/block size and vulnerable to modern practical breaks (such as Sweet32 and fluency attacks).
- *There is no technical difference; they are interchangeable terms:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.

4) A — Accounting (Auditing / Log accounting).

✓ **Why it is correct:** Accounting is the responsibility to monitor, track, and record all user actions and sessions for auditing and compliance purposes. In this scenario, the lack of logs and access history indicates a failure in accounting.

✗ **Why the others are wrong:**

- *Authentication:* Authentication verifies the identity of a user, but the scenario does not indicate that identity verification failed; it indicates that actions were not logged.

- *Availability*: Availability ensures that systems and data are accessible when needed, but the scenario does not mention any denial of service or downtime.
- *Authorization*: Authorization determines what a user is allowed to do, but the scenario does not indicate that a user performed actions beyond their permissions; it indicates that actions were not recorded.

5) A — TACACS+ completely separates authentication and authorization and encrypts the entire TCP packet (port 49).

✓ **Why it is correct:** TACACS+ uses TCP 49, encrypts the entire message body, and strictly separates authentication and authorization processes, allowing command-by-command granularity.

✗ **Why the others are wrong:**

- *TACACS+ does not require passwords or certificates*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *RADIUS encrypts the entire packet while TACACS+ encrypts nothing*: RADIUS encrypts only the password field; headers and other attributes travel in cleartext (TACACS+ is the one that encrypts the entire payload).
- *RADIUS uses guaranteed TCP while TACACS+ uses UDP without confirmation*: TACACS+ uses exclusively TCP port 49 for reliable transport, while RADIUS uses UDP ports (1812/1813).

6) A — Authentication.

✓ **Why it is correct:** MFA is a mechanism exclusive to the Authentication pillar (identity validation through multiple independent factors).

✗ **Why the others are wrong:**

- *Accounting*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Federation*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Authorization*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.

7) A — Authentication was successful, but Authorization was denied by the privilege policy.

✓ **Why it is correct:** The system successfully recognized who the user is (Authentication OK), but checked its access control list (ACL) and determined that the user does not have permission for that resource (Authorization Denied). This is a classic example of the distinction between authentication and authorization.

✗ **Why the others are wrong:**

- *The AAA model was corrupted and the server crashed*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *The Accounting audit blocked the user due to inactivity*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *The user needs to change their asymmetric key*: Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.

8) A — Acts as the Authenticator (Network Access Server - NAS), mediating packets between the client and the RADIUS server.

✓ **Why it's correct:** In the 802.1X/RADIUS model, the Access Point is the Authenticator (NAS/Pass-through): it does not store credentials, it only forwards requests from the supplicant (client) to the authentication server.

✗ **Why the others are wrong:**

- *Acts as the password database server itself:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Acts as an offline root certificate authority:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Plays only the Accounting role without touching authentication:* Legacy cipher with insufficient key/block size and vulnerable to modern practical breaks (such as Sweet32 and fluency attacks).

9) A — Real-time log forwarding to a centralized external SIEM server with WORM retention rules.

✓ **Why it's correct:** Centralized and immediate log forwarding to an external SIEM (or secure syslog) prevents an intruder with local access to the compromised machine from deleting evidence of the intrusion. This ensures logs are stored off-host, where the attacker cannot tamper with them, and WORM (Write Once Read Many) retention rules further protect log integrity.

✗ **Why the others are wrong:**

- *Storing logs only in volatile RAM:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam. Volatile memory is lost on reboot and can be altered by an attacker with system access.
- *Automatically deleting logs every 24 hours:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam. It also destroys forensic evidence and violates retention compliance requirements.
- *Disabling logs on accounts with administrator privileges:* This is a legacy cipher with insufficient key/block size and vulnerable to modern practical breaks (such as Sweet32 and fluency attacks). Disabling logs on privileged accounts removes critical audit trails, enabling insider threats and making incident response impossible.

10) A — Identity Provider (IdP), responsible for authenticating the user and issuing the assertion token.

✓ **Why it's correct:** In SAML federation, the IdP (such as ADFS or Okta) is responsible for authenticating the user and providing a signed assertion token to the Service Provider.

✗ **Why the others are wrong:**

- *Service Provider (SP), responsible only for hosting email:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Reverse proxy server without a security function:* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.
- *Web Application Firewall (WAF):* Does not meet the technical requirement presented in the scenario, contradicting best practices and controls required by the CompTIA Security+ exam.

